Defensive Security Project

Table of Contents

This document contains the following resources:

01

Monitoring Environment

02

Attack Analysis

03

Project Summary & Future Mitigations

Monitoring Environment

Scenario

- Today, we are acting as a SOC analyst for Virtual Space Industries (VSI), a company that develops virtual reality programs for businesses. VSI suspects that a competitor, JobeCorp, may be launching cyberattacks to disrupt operations. Our job is to use Splunk to monitor for potential threats. Recently, our manager informed me that VSI suffered multiple attacks, likely from JobeCorp, which took down several systems. Luckily, we had just set up monitoring solutions to track attacks, particularly on VSI's Windows and Apache servers. Management has provided additional logs from the affected systems during the attack period. Now, we must analyze these logs to evaluate the effectiveness of our defenses.

Ipinfo App

Ipinfo app

Our group chose the “Ipinfo” app, we chose this because this can be very beneficially for filtering out potential attackers. Ipinfo is a very simple addon that you can switch on to quickly search up a lot of information about a ip address that normal iplocation wouldn’t give you. Also it is a lot more user friendly than iplocation for newer splunk users who just want to get a information about a ip address without even knowing what they are looking for.

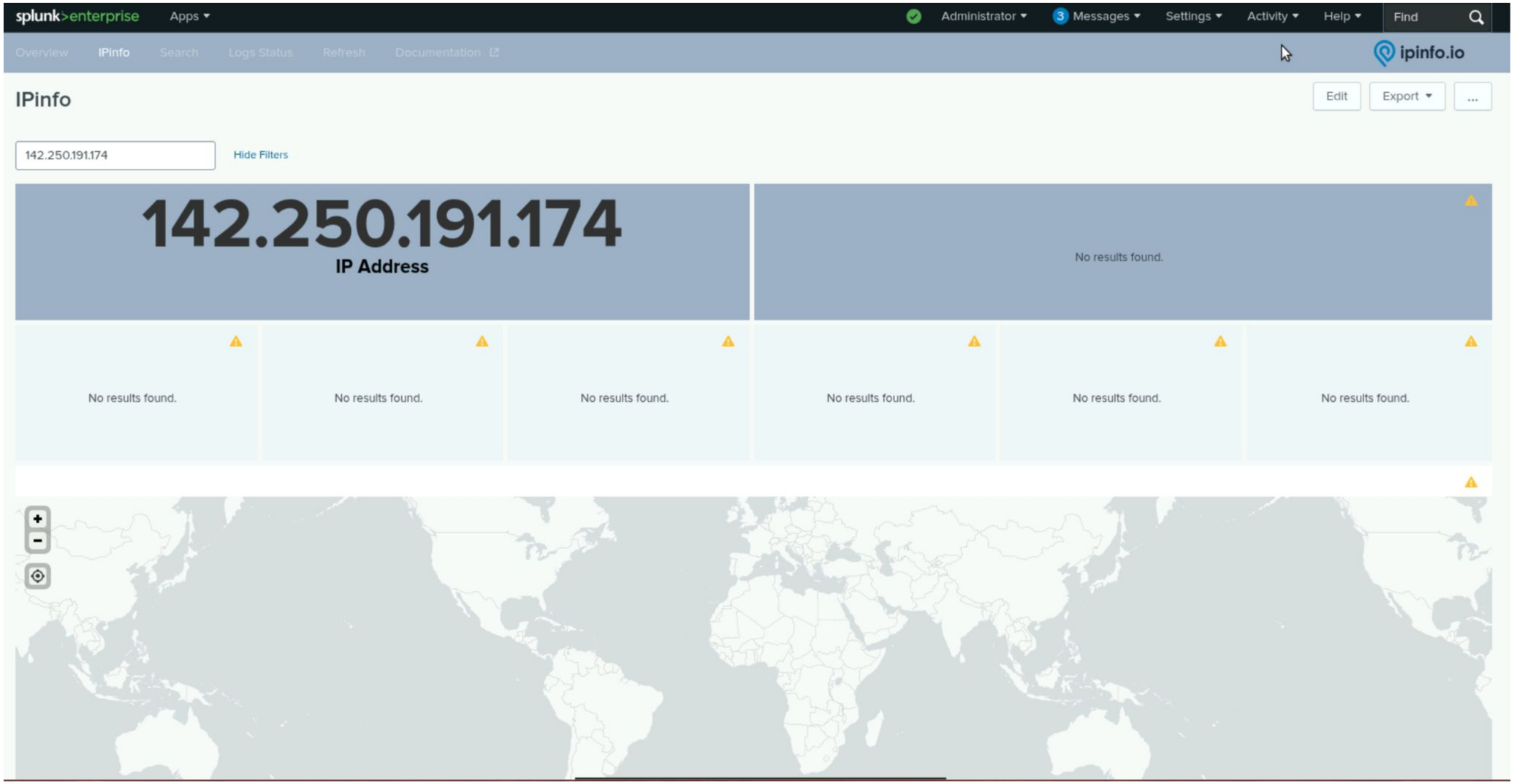
Ipinfo app

A great scenario is let’s say your company hosts a web app that ships products in the U.S. But once a week on the same day and hour an ip address sends 10,000 requests a minute.

The company individually bans those ip addresses but a new once comes back once a week. In that scenario a splunk engineer can use Ipinfo on those ip addresses and find out that those users are using a proxies. Since this website isn’t for anonymous users and is for actual buyers/sellers. Then it is a easy decision to ban proxies all together especially if it isn’t used by actual customers.

Ipinfo app

It is just a simple tab to switch over. Ignore “No results found” api key isn’t working for some reason so ignore that.



Logs Analyzed

1 Windows Logs

The logs contained various information like times with fields like date_hour etc. Along with usernames, actions (signatures) and more.

2 Apache Logs

The logs contained information about the HTTP methods like POST, HEAD and OPTIONS. They also included information about user count and suspicious referrers.

Windows Logs

Reports—Windows

Report Name	Report Description
Signatures & associated signatures	A table that shows a signature_id along with it’s associated signature
Severity report	A table that shows the severity type, the count and the percentage of the severity
Signature count	A graph that shows the signature_id along with the signature count of that id
Signature values overtime line chart	A line chart that shows overtime how much a type of signature has been happening. For example a users have logged in 15 times at 8am.

Reports—Windows Extended

Report Name	Report Description
Status report	A table that shows the type of status (failure/success) along with the count and the percentage of each
User count	A graph that shows how often a username appears in logs so the format is “username” appears x times
User fields over time	It is similar to user count except it shows how often a user appears in a given hour over time

Images of Reports—Windows

Signatures & associated signatures

signature_id	signature
4726	A user account was deleted
4720	A user account was created
4743	A computer account was deleted
4624	An account was successfully logged on
4672	Special privileges assigned to new logon
4724	An attempt was made to reset an accounts password
4717	System security access was granted to an account
4673	A privileged service was called
4648	A logon was attempted using explicit credentials
4740	A user account was locked out

« Prev 1 2 Next »

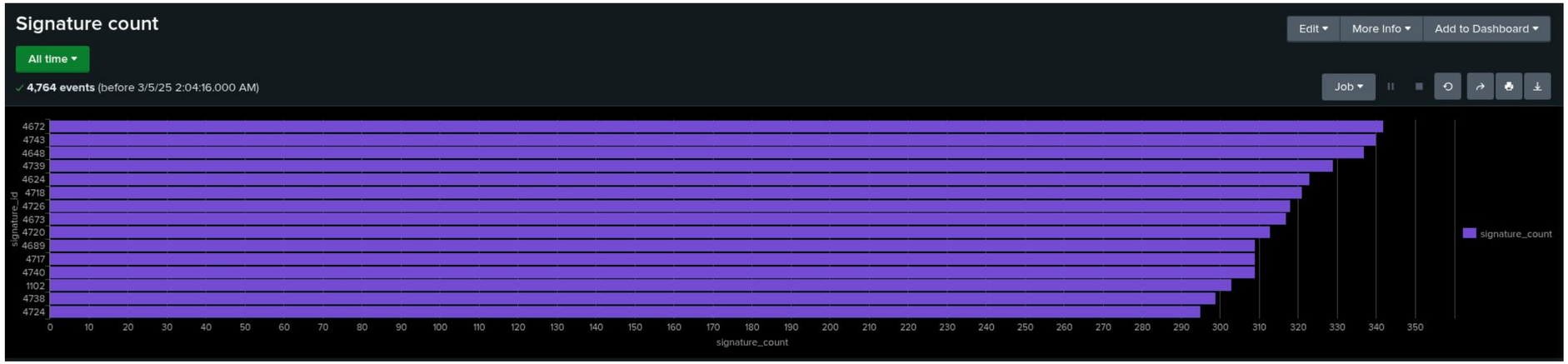
Severity report

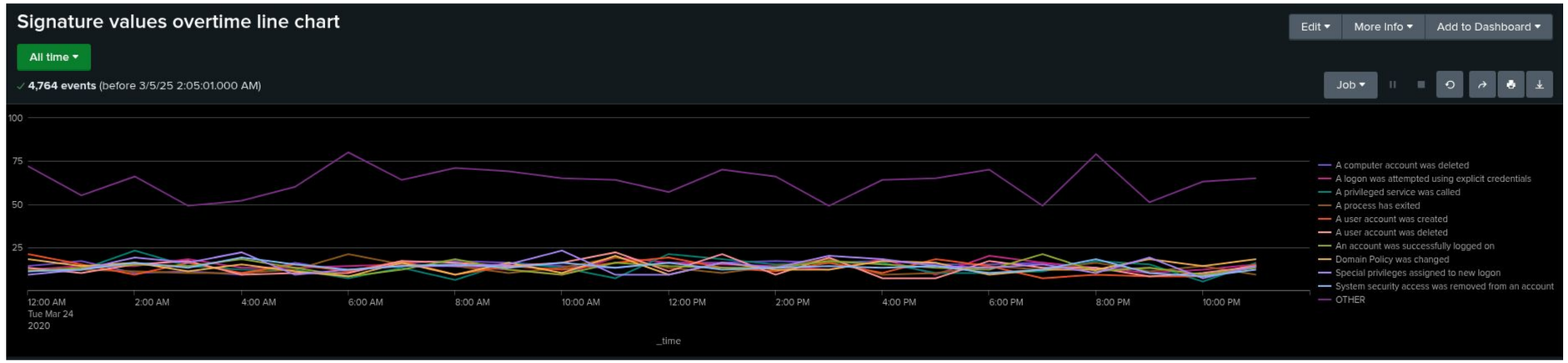
severity	severity_count	percentage
high	329	6.905961376994123
informational	4435	93.09403862300589

Status report

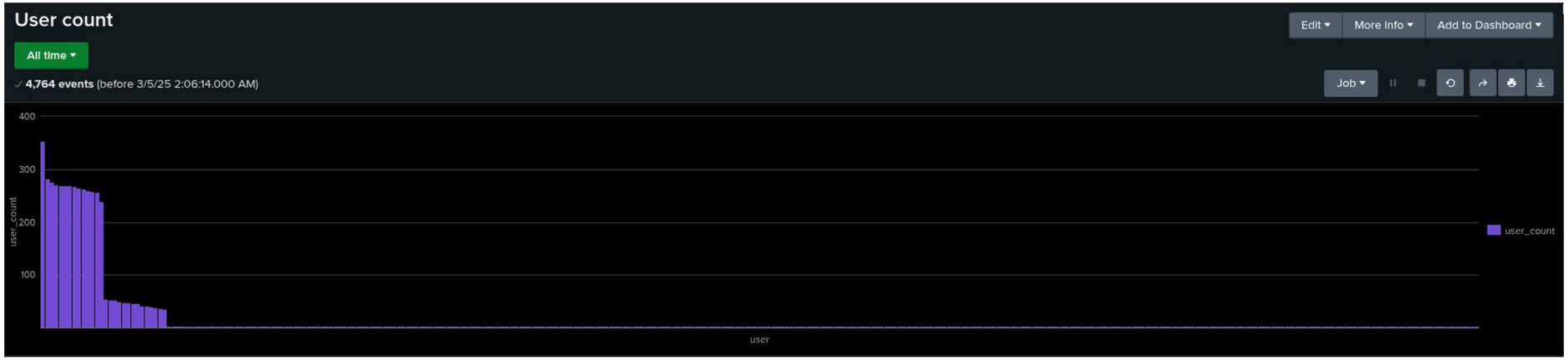
status	status_count	percentage
failure	142	2.980688497061293
success	4622	97.0193115029387

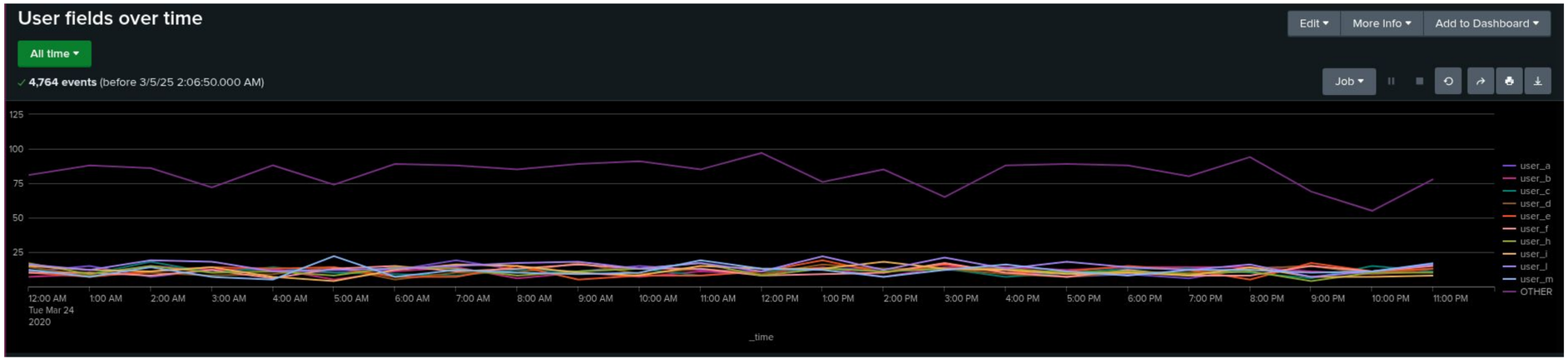
Images of Reports—Windows





Images of Reports—Windows





Alerts—Windows

Designed the following alerts:

Alert Name	Alert Description	Alert Baseline	Alert Threshold
Hourly failed windows activities	If the certain threshold of status=”failure” (failed activity) hits then alert will trigger	20	24

JUSTIFICATION: 20 was my baseline since it was the highest and it has been hit twice in 2 separate hours. I chose 24 as the threshold since I can see it hit 22 in a one off occasion but mid 20s does seem excessive.

Alerts—Windows

Designed the following alerts:

Alert Name	Alert Description	Alert Baseline	Alert Threshold
Hourly successful logins	If the certain threshold of signature_id=”4624” (successful login) hits then alert will trigger	34	42

JUSTIFICATION: Most successful logins follow around the mid to low 30s so 34 makes adequate sense. My second highest value was 36 and my highest was 42. So since 42 is an outlier so that seems to be the perfect threshold.

Alerts—Windows

Designed the following alerts:

Alert Name	Alert Description	Alert Baseline	Alert Threshold
Hourly of deleted users	If the certain threshold of signature_id=”4726” (delete user) hits then alert will trigger	36	50

JUSTIFICATION: I chose 36 for baseline since most results tend to be around mid to high 30s so 36 represents it well. For threshold I chose 50 even though the highest is 44, most of the data is very sporadic so 50 is a safe bet.

Dashboards—Windows

Windows Server Monitoring

Edit | Export | ...

Last 24 hours | Hide Filters

signature_id	signature
4726	A user account was deleted
4720	A user account was created
4743	A computer account was deleted
4624	An account was successfully logged on
4672	Special privileges assigned to new logon
4724	An attempt was made to reset an accounts password
4717	System security access was granted to an account
4673	A privileged service was called
4648	A logon was attempted using explicit credentials
4740	A user account was locked out

« Prev 1 2 Next »

status	status_count	percentage
failure	142	2.980688497061293
success	4622	97.0193115029387

severity	severity_count	percentage
high	329	6.905961376994123
informational	4435	93.09403862300589

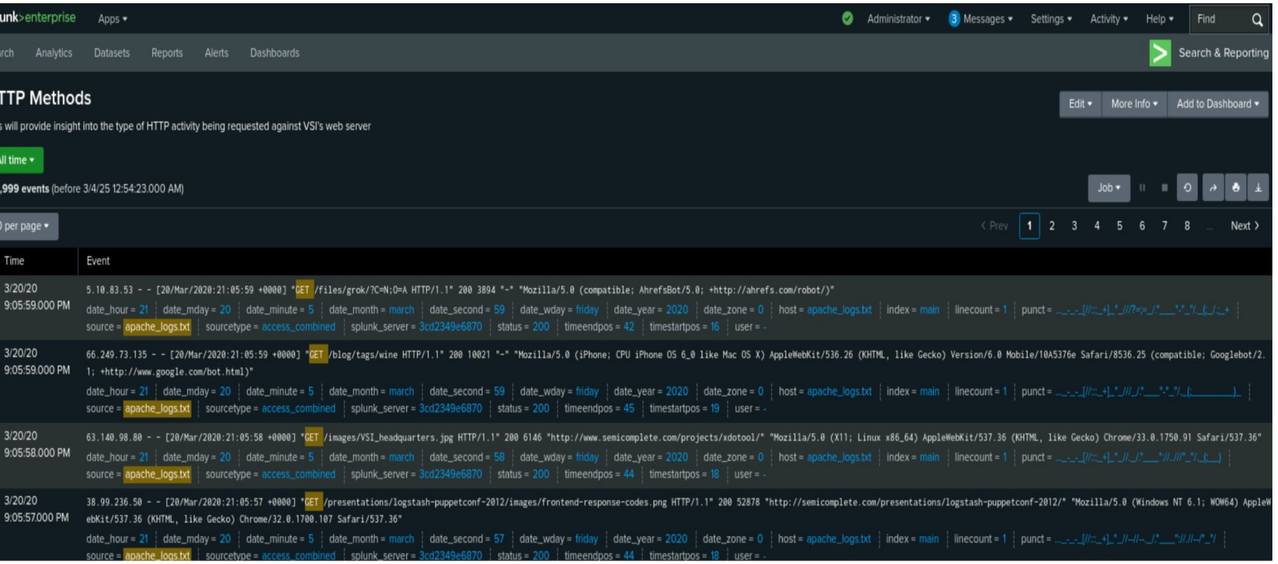
Apache Logs

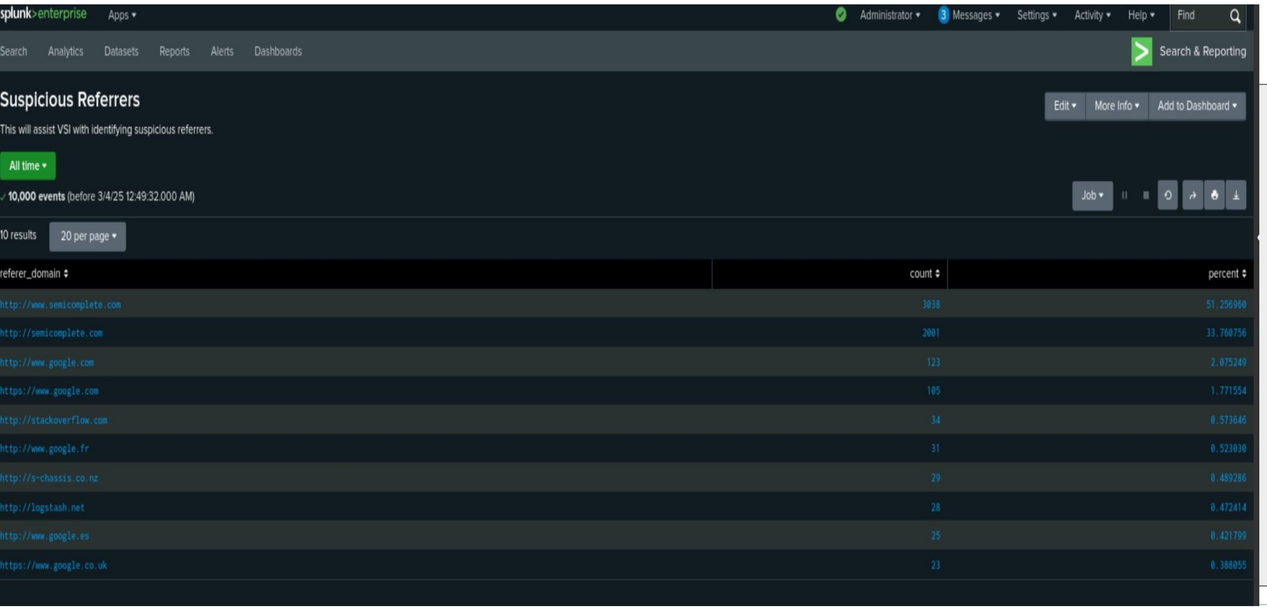
Reports—Apache

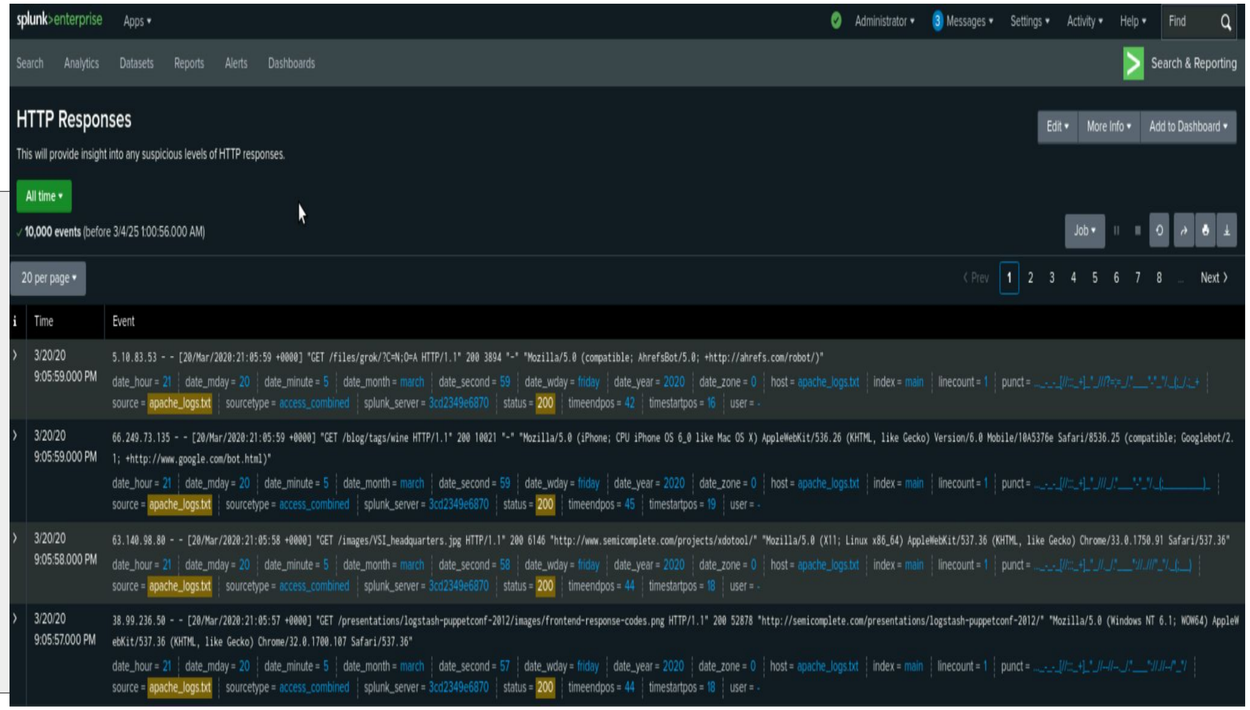
Designed the following reports:

Report Name	Report Description
HTTP Methods	Identifies the types of HTTP requests made
Suspicious Referrers	Identifies suspicious referrers
HTTP Response Code	Detects unusual patterns in HTTP responses

Images of Reports—Apache







Alerts—Apache

Designed the following alerts:

Alert Name	Alert Description	Alert Baseline	Alert Threshold
Hourly Activity From Any Country Other Than the United States	Creates an alert that's triggered when a country other than the US reach the threshold	280	400

JUSTIFICATION: Hourly alerts to monitor activity from countries other than the United States. Every hour an alert will be sent out for any logs from countries other than the U.S. If the country reaches the threshold, the alert will be triggered.

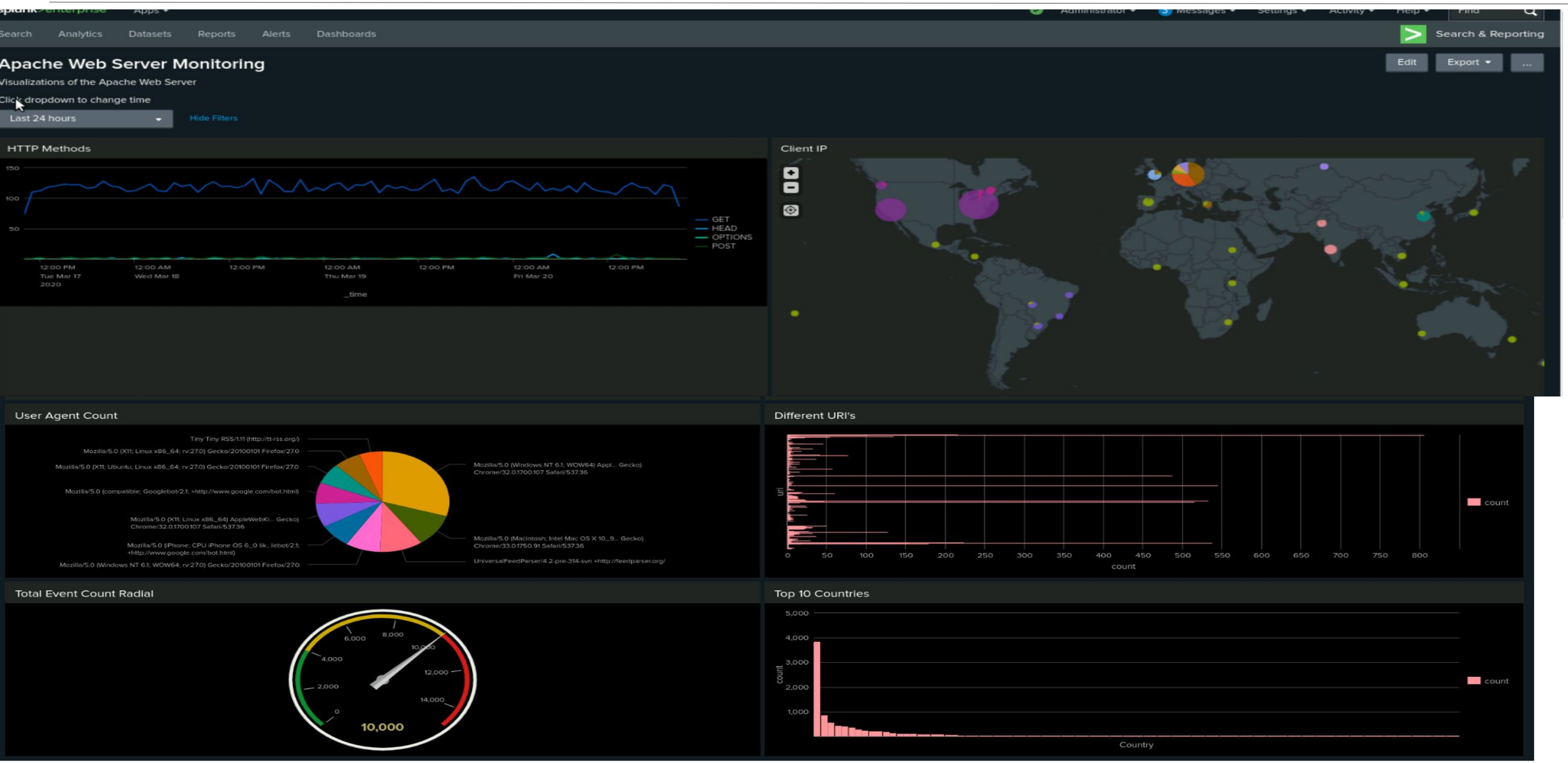
Alerts—Apache

Designed the following alerts:

Alert Name	Alert Description	Alert Baseline	Alert Threshold
Hourly Count of HTTP POST Method	Creates alert when the threshold for the hourly HTTP POST count has been reached.	3	5

JUSTIFICATION: When the HTTP POST method logs reach 5, it will trigger the alert. 5 was selected as the threshold due to the average amount of POST logs being about 3 or 4.

Dashboards—Apache



Attack Analysis

Attack Summary—Windows

Summarize your findings from your reports when analyzing the attack logs.

- When analyzing the windows attack logs the severity of "high" has went from approximately 6.91 to 22.2 percent.
- Failed activities went from 3% all the way to 1.6% after adding attack logs to the query. So it was slightly over half that from the original server logs.

Attack Summary—Windows

Summarize your findings from your alerts when analyzing the attack logs. Were the thresholds correct?

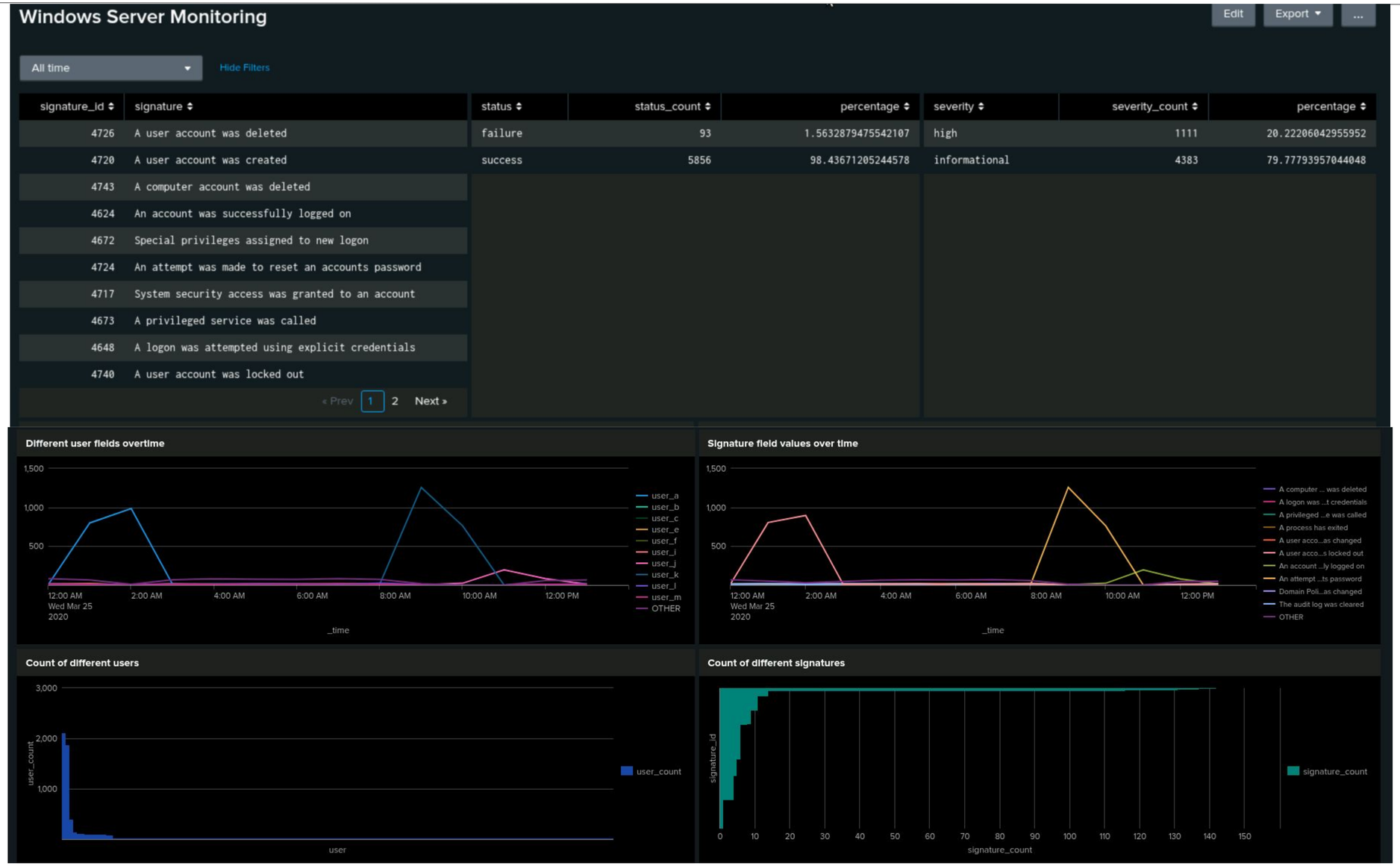
- In my failed windows activities alert, it would’ve triggered because the highest amount of failed activities was 70 and it was at 8 hour mark. So I wouldn’t change my threshold.
- For the successful logins alert, the highest of 32 is way lower than my threshold. So I wouldn’t change anything nothing looks suspicious in those logs.
- The same can be said for deleted users as well the attack logs overall looked lower than normal so I am assuming it is fine.

Attack Summary—Windows

Summarize your findings from your dashboards when analyzing the attack logs.

- Summarize your findings from your dashboards when analyzing the attack logs.
- So from comparing my dashboard from the regular logs to attack ones, I can definitely tell something odd is going on
- My two graphs “Different user fields overtime” and “Signature field values over time” are remarkably similar
- Those two humps on each graph is caused by two users. user_a about 900 times at 2 am has committed the signature “A user account as been locked out”
- While user_k at 9 am did the signature “An attempt was made to reset an accounts password” about 1,200 times
- Lastly they appear the most on my “count of different users” chart and their signatures appear at the top of my “count of different signatures” chart.

Screenshots of Attack Logs



signature_id	signature
4726	A user account was deleted
4720	A user account was created
4743	A computer account was deleted
4624	An account was successfully logged on
4672	Special privileges assigned to new logon
4724	An attempt was made to reset an accounts password
4717	System security access was granted to an account
4673	A privileged service was called
4648	A logon was attempted using explicit credentials
4740	A user account was locked out

« Prev 1 2 Next »

status	status_count	percentage
failure	93	1.5632879475542107
success	5856	98.43671205244578

severity	severity_count	percentage
high	1111	20.22206042955952
informational	4383	79.77793957044048

Attack Summary—Apache

Summarize your findings from your reports when analyzing the attack logs.

- We seen a increase in POST in the HTTP Methods report. We also detected a robot.txt in a GET request log.
- We also detected an OPTIONS method.
- There wasn't any record of suspicious activity in the referrer domains.
- We noticed an increase in the 404 status from 2.13% to 15.099% in the HTTP Response report. We noticed repeated 404 errors.

Attack Summary—Apache

Summarize your findings from your alerts when analyzing the attack logs. Were the thresholds correct?

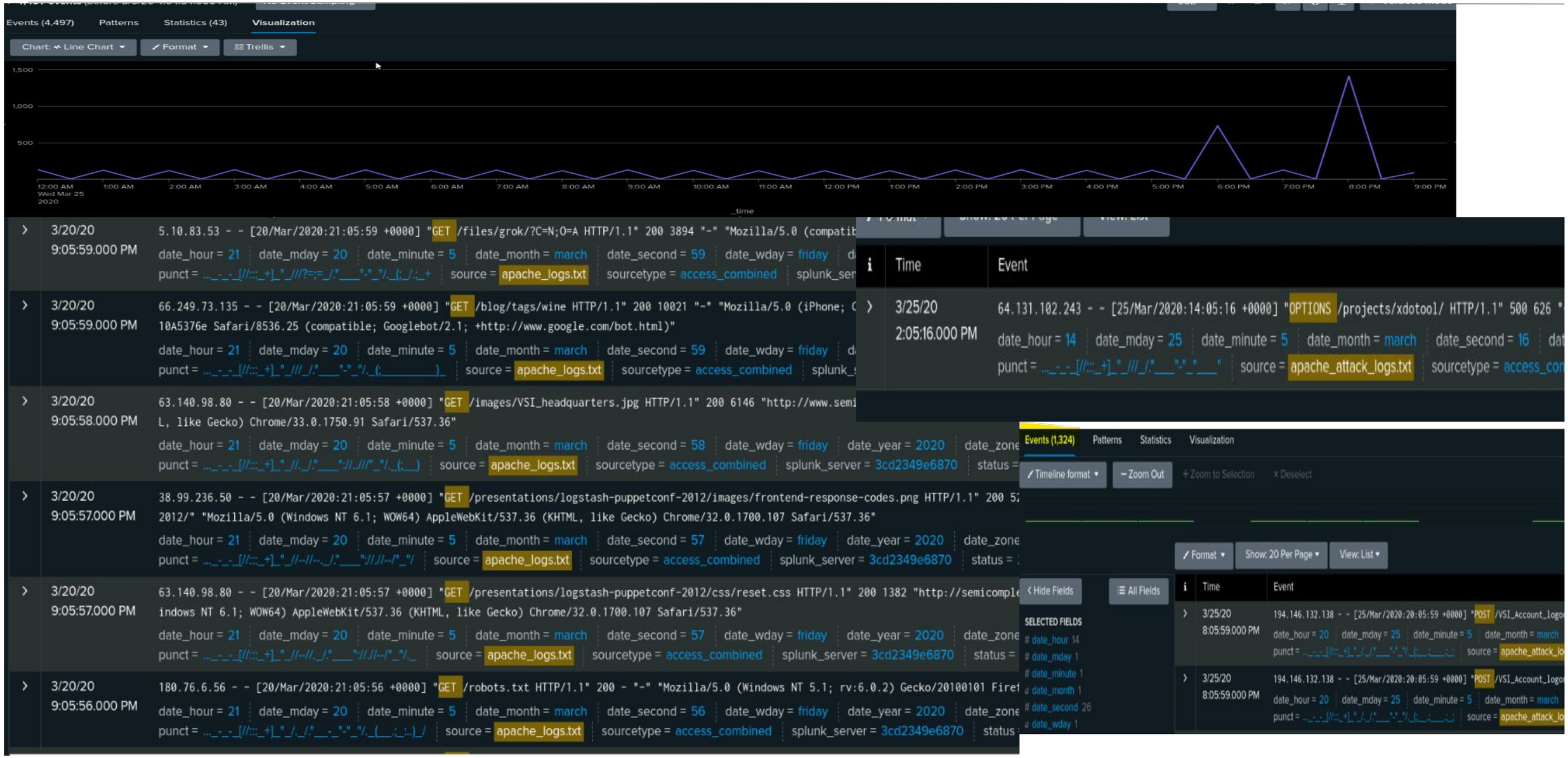
- We seen a suspicious increase in volume at 6pm of 730 and at 8pm of 1,415.
- Our threshold was correct and the alert would have been triggered based on the reports.
- We also noticed suspicious activity with an increase in HTTP POST methods around 8pm. It peaked at 1,296. Our threshold was also correct for this alert.

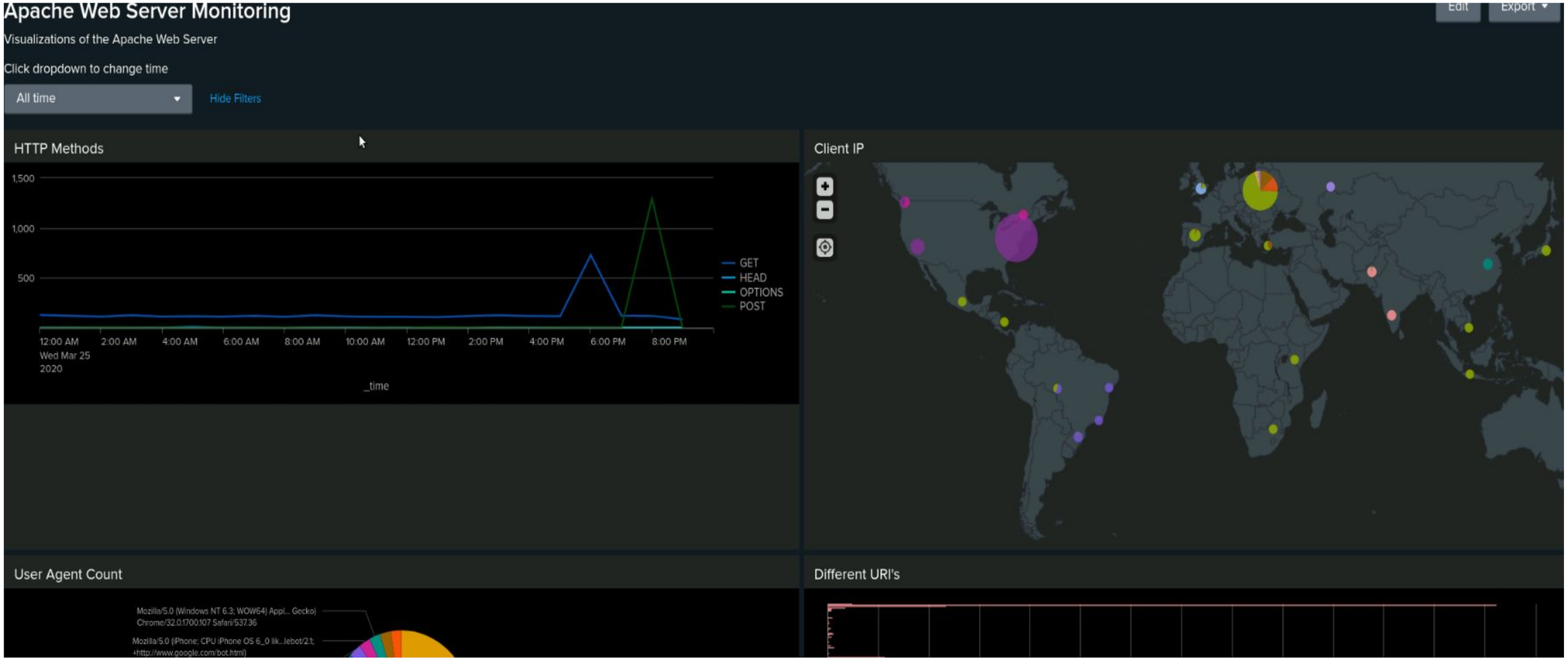
Attack Summary—Apache

Summarize your findings from your dashboards when analyzing the attack logs.

- We noticed big clusters located on the United States and Ukraine. As we zoomed in the on the map, we were able to see more detailed information.
- Washington DC had the highest volume of activity with a count of 724. New York had 670, Kiev had 440 and Kharkiv had 432.
- After analyzing our URI Data, we noticed high volume from /VSI_Account_logon.php. It had a count of 1,323.
- The attacker is trying to gain access through brute force.

Screenshots of Attack Logs




Apache Web Server Monitoring
Visualizations of the Apache Web Server
Click dropdown to change time
All time
Hide Filters
Edit
Export
HTTP Methods
1,500
1,000
500
12:00 AM
Wed Mar 25
2020
2:00 AM
4:00 AM
6:00 AM
8:00 AM
10:00 AM
12:00 PM
2:00 PM
4:00 PM
6:00 PM
8:00 PM
_time
GET
HEAD
OPTIONS
POST
Client IP
User Agent Count
Different URI's

Project 3 Summary

- What were your overall findings from the attack that took place?

Our analysis identified multiple brute force attacks on our Windows and Apache servers. It consisted of login attempts and repeated password reset requests. The attackers sought unauthorized access by testing various credentials across multiple accounts.

- To protect VSI from future attacks, what future mitigations would you recommend?

These findings emphasize the necessity of strengthening security measures. We can restrict the number of login attempts. We can also require multi-factor authentications for all users and deploy firewalls to detect login attempts.

Summary and Future Mitigations